



IT-Security

Chapter 7: Secure Communication

1. SSL / TLS
2. WLAN / WiFi





What do we want to learn?



- ▶ How do I communicate securely over open networks?
- ▶ Which protocols are used for this?
- ▶ How does SSL/TLS work?
- ▶ How do I make WLAN secure?
- ▶ We are only looking at a small aspect of secure communication here.
- ▶ Further aspects can be found in other lectures on the topic of computer networks.



Chapter 7.1: SSL / TLS

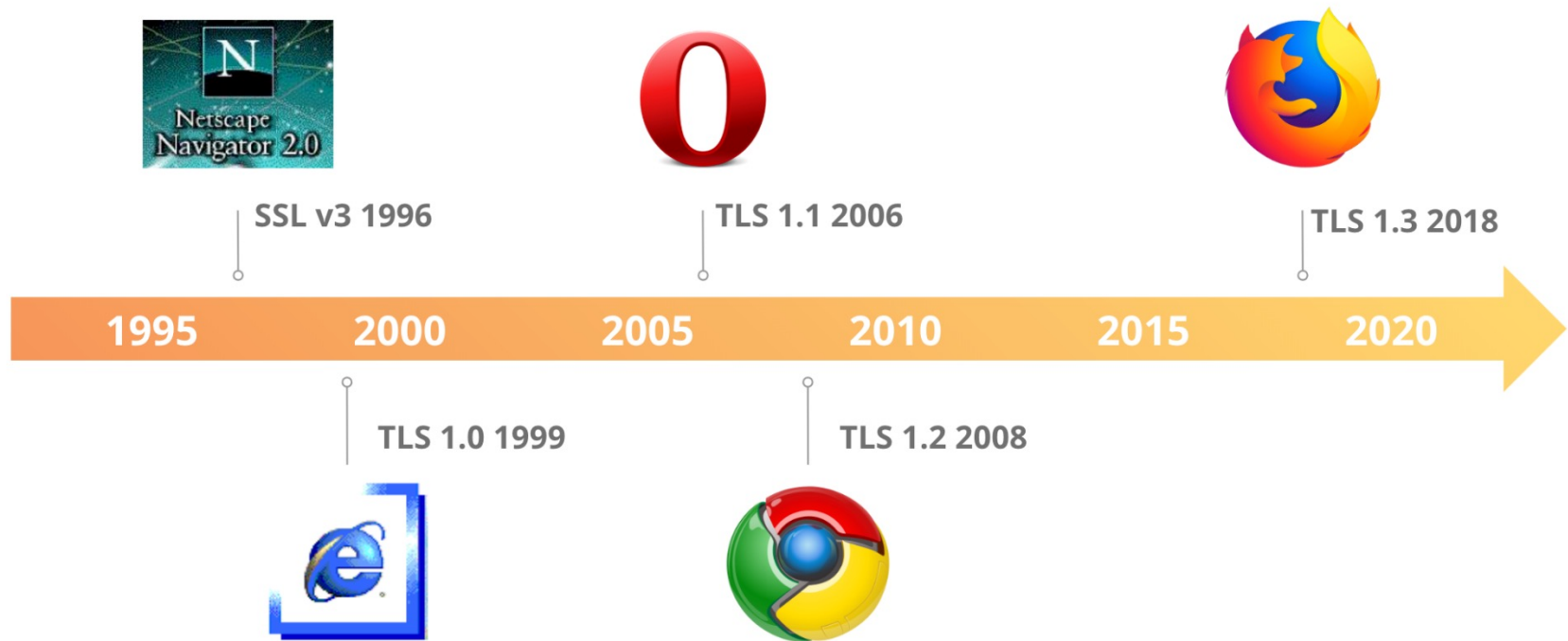
- Protocol
- Vulnerabilities and exploits
- TLS 1.3

Secure network protocols on the Internet

Application layer, e.B. HTTP, SMTP, ...
SSL / TLS security
Transport layer with TCP or UDP
IPSEC security
Internet Protocol
WLAN security (WEP, WPA/2, EAP)
Transmission layer e.g. Ethernet, WLAN, ...



The history of SSL/TLS

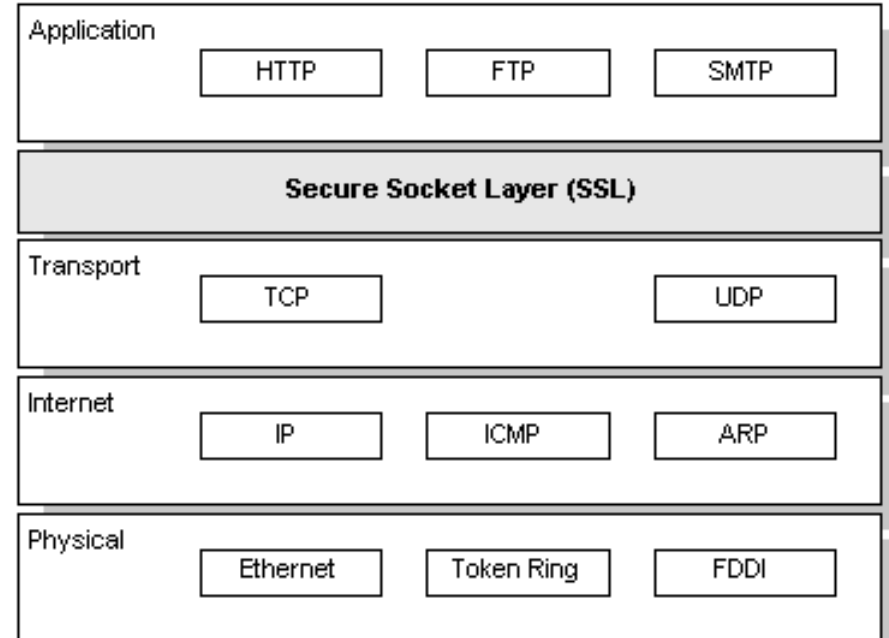


<https://blog.cloudflare.com/rfc-8446-aka-tls-1-3/>



SSL (Secure Socket Layer), TLS (Transport Layer Security)

- ▶ Developed by Netscape in 1994, widely used industry standard
- ▶ Since 1999 IETF Standard TLS Transport Layer Security
- ▶ Securing communication between the WWW client and the WWW server
 - ▶ already integrated in the web browser and web server
 - ▶ only installation of keys and certificates and use of https necessary
- ▶ Transport Layer security
 - ▶ Located between transport layer and application layer
 - ▶ Does not interfere with TCP communication (see IPSEC)





SSL/TLS: cryptographic and organizational aspects

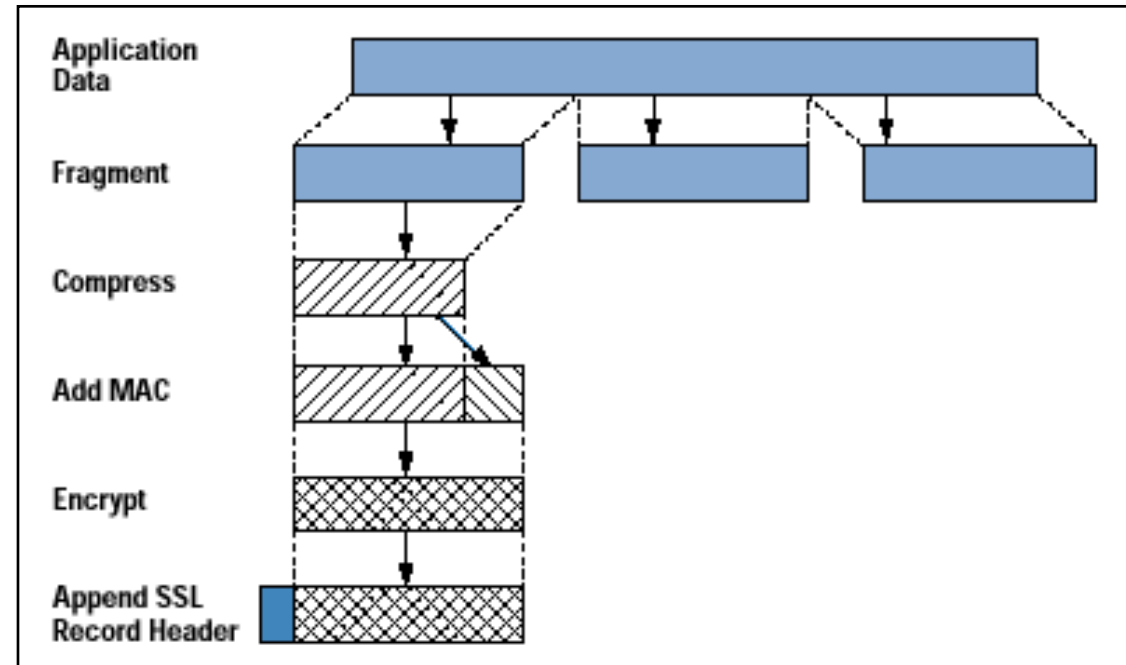
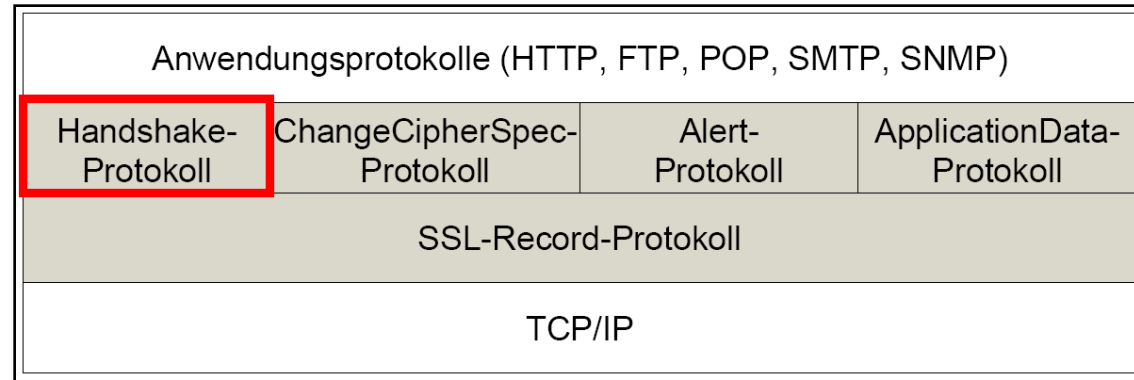
- ▶ Security Objectives
 - ▶ **Confidentiality:** "hybrid" crypto system, asymmetric key exchange methods, symmetric encryption
 - ▶ **Integrity:** Calculation of cryptographic checksums (Message Authentication Code, MAC)
 - ▶ **Authenticity:** Use of certificates
- ▶ Organizational aspects
 - ▶ requires installation and management of server certificates
 - ▶ the protection of the private server key is important
 - ▶ requires additional computing power for cryptographic operations
 - ▶ https sends http requests and responses over an SSL connection (port 443)
 - ▶ enables protected data transfer but no end-to-end security
→ usually ends at the firewall



SSL/TLS Protocol Layers

- ▶ **Handshake layer**
 - ▶ coordinates and manages client and server state information
 - ▶ authentication, negotiation procedures, exchange of information
- ▶ **Record Layer**
 - ▶ fragments and compresses data packets into SSL records
 - ▶ calculates MAC for the data
 - ▶ encrypts data together with MAC
 - ▶ receives key data from the handshake layer

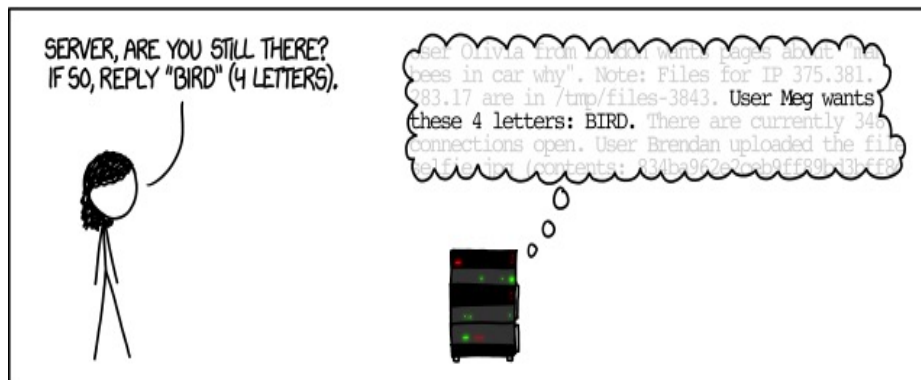
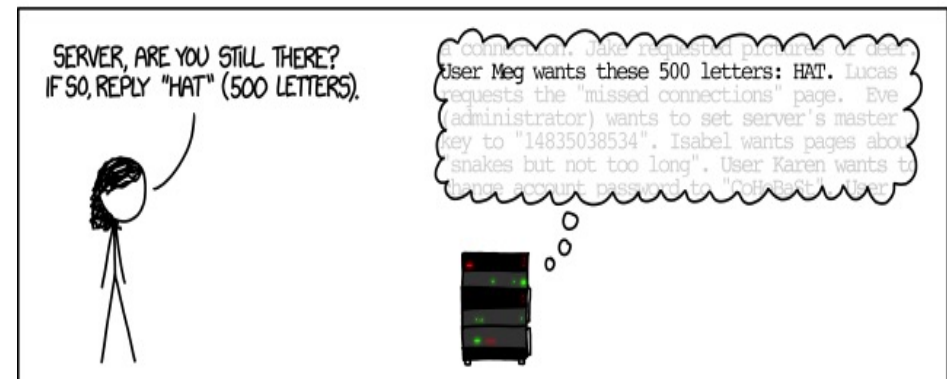
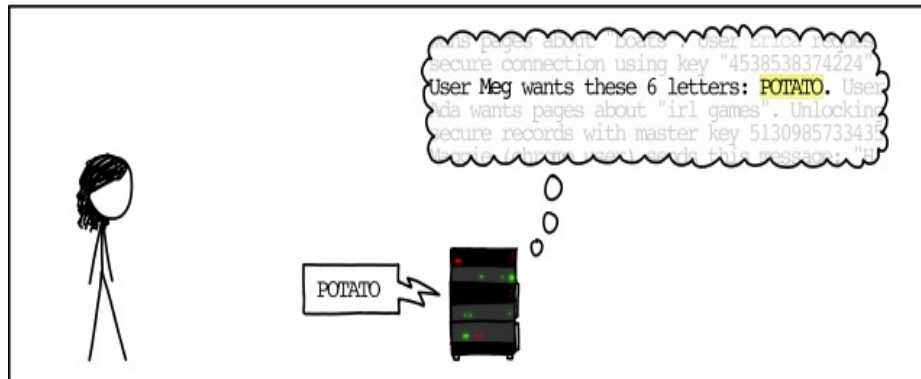
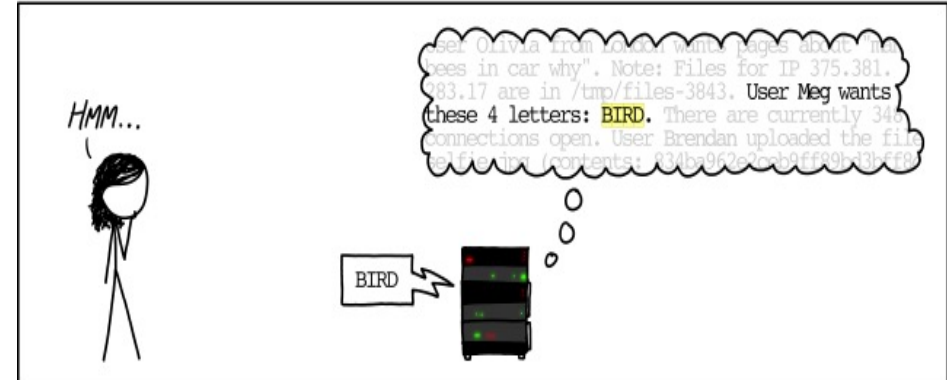
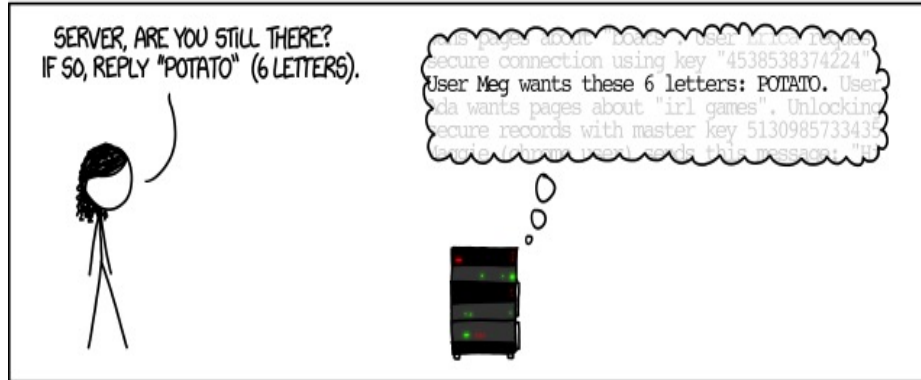
Quelle: Vorlesung IT-Sicherheit TUM, Prof. Dr. Claudia Eckert





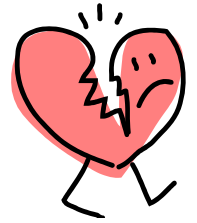
HOW THE HEARTBLEED BUG WORKS:

Quelle: <http://xkcd.com/1354/>



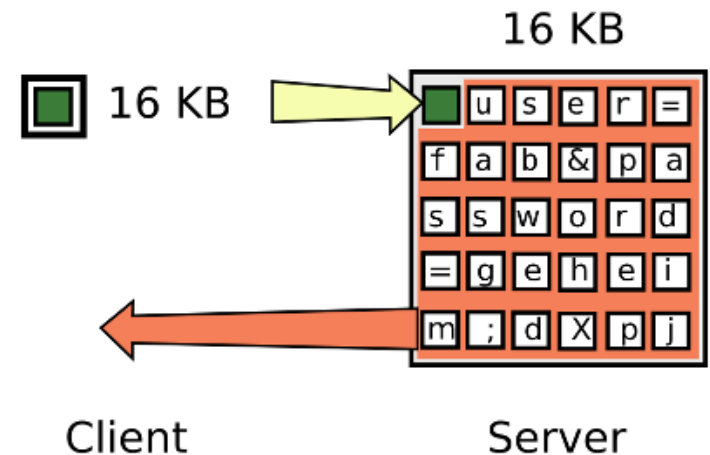


OpenSSL TLS Protocol Vulnerability: Heartbleed Exploit 2014



- ▶ OpenSSL has implemented a heartbeat feature in the TLS protocol to keep TLS connections alive
- ▶ Heartbeat function: Client sends payload with arbitrary content, server sends it back
- ▶ Problem: In implementation there was a field with the length of the payload, but it was not checked if payload actually has the length

- ▶ Attack:
 - ▶ Client sends only one byte payload, but length 64 KByte
 - ▶ Server writes one byte to its memory
 - ▶ Server sends 64 KB from its memory back to the client, which can contain usernames and passwords



Quelle: <http://www.heise.de/security/artikel/So-funktioniert-der-Heartbleed-Exploit-2168010.html>



The Java exploit for Heartbleed has 186 lines of code The patch has only 8 lines of code

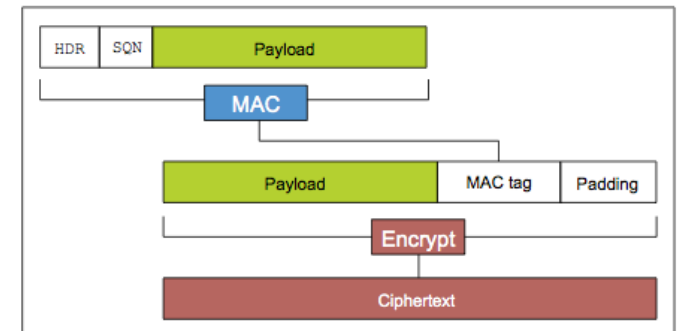
```
-    /* Read type and payload length first */
-    hbtype = *p++;
-    n2s(p, payload);
-    pl = p;
-
-    if (s->msg_callback)
-        s->msg_callback(0, s->version, TLS1_RT_HEARTBEAT,
-            &s->s3->rrec.data[0], s->s3->rrec.length,
-            s, s->msg_callback_arg);

+    /* Read type and payload length first */
+    if (1 + 2 + 16 > s->s3->rrec.length)
+        return 0; /* silently discard */
+    hbtype = *p++;
+    n2s(p, payload);
+    if (1 + 2 + payload + 16 > s->s3->rrec.length)
+        return 0; /* silently discard per RFC 6520 sec. 4 */
+    pl = p;
+
```

Bounds check
with correct
record length

▶ Vulnerability in TLS protocol (up to TLS 1.2): Poodle

- ▶ "Today it is clear that **encrypt-then-MAC**, i.e. encrypting and then securing, would have been the better choice for SSL/TLS. But this knowledge was not available to the designers of the protocol at the time, and we have to live with its weaknesses today."
- ▶ The attack is not easy and requires **three stages**
 - ▶ Perform a Man in the Middle attack
 - ▶ Convince the server to use SSL 3.0
 - ▶ Perform the complicated POODLE attack:
 - ▶ force the browser to run JavaScript code
 - ▶ try many requests
 - ▶ modify the URL and copy blocks of the encrypted request to the padding,
 - ▶ Server responds if MAC or Padding is wrong
 - ▶ After many modified requests with padding errors attacker can guess the padding pattern and some bytes of the plaintext of the previous block



<https://www.techtarget.com/whatis/definition/POODLE-attack>

<https://www.manageengine.com/key-manager/information-center/what-is-poodle-attack.html>



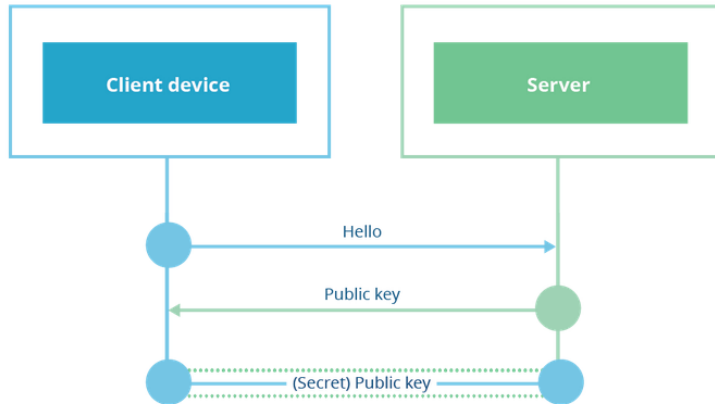
Improving TLS with TLS 1.3

- ▶ Released in August 2018 as RFC 8446
- ▶ Reason: TLS 1.2 (2008) has some vulnerabilities, there are many attacks
- ▶ Innovations
 - ▶ numerous insecure crypto algorithms and procedures are abolished (e.g. SHA1, MD5, RC4, CBC)
 - ▶ only AEAD algorithms for symmetric encryption allowed (Authenticated Encryption with Associated Data)
 - ▶ key exchange only with DH via ECC (ECDHE), RSA key exchange deleted
 - ▶ new Cipher Suites
 - ▶ improved handshake: Establishing a connection with only one round-trip
 - ▶ higher performance

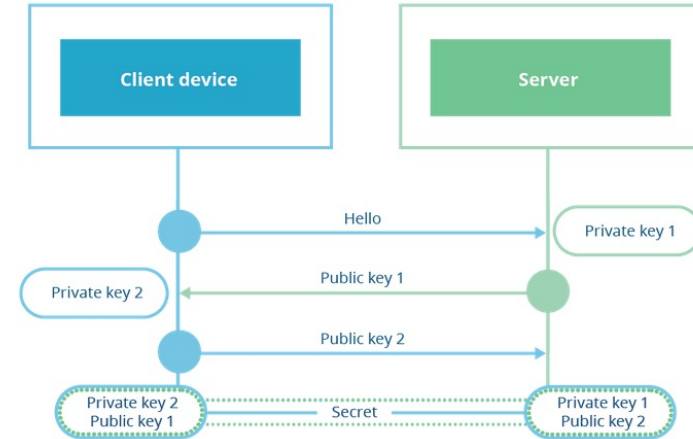


Key Exchange in TLS 1.2

RSA handshake



DH 1.2 handshake



<https://blog.cloudflare.com/rfc-8446-aka-tls-1-3/>

▶ RSA Handshake

- ▶ client selects shared key (secret)
- ▶ encrypts it with public key from server and sends it to the server

▶ Diffie Hellman Handshake

- ▶ client and server create a public-private key pair
- ▶ they exchange the public shares and calculate a common key (secret, pre-master-key)



Perfect Forward Secrecy for Cryptographic Protocols

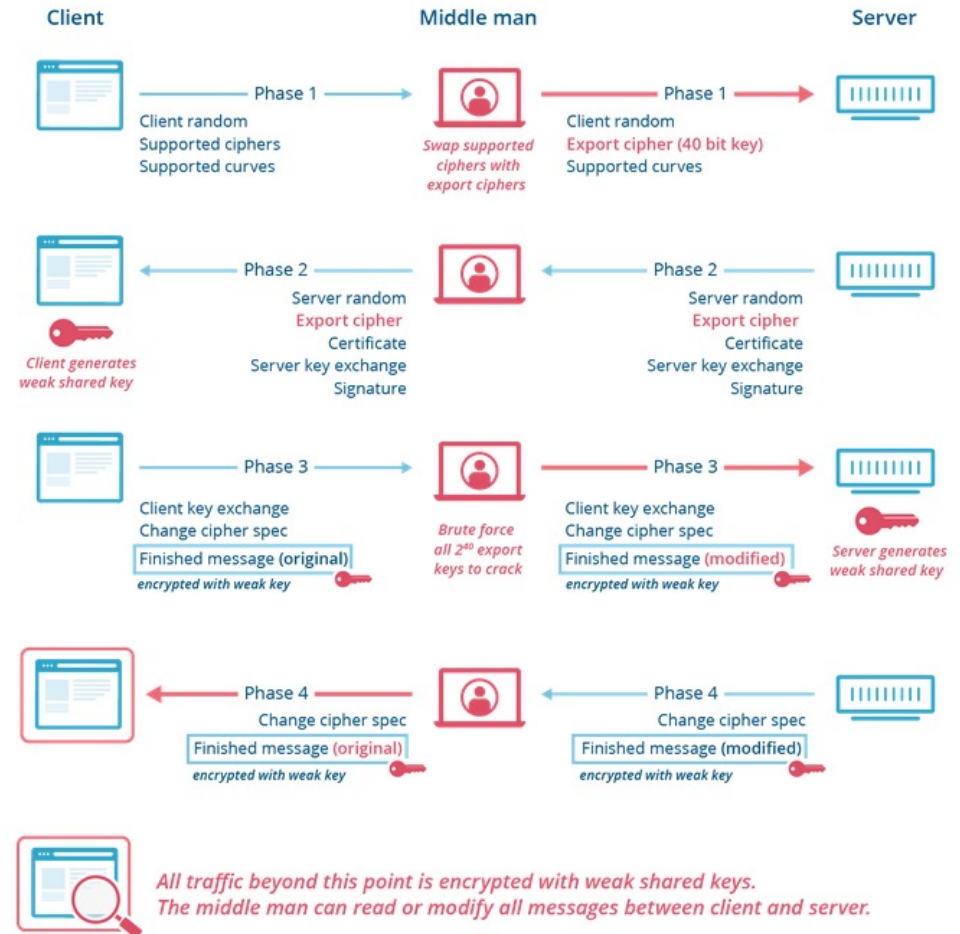
- ▶ The Principle
 - ▶ client and server agree on a key that never goes over the network and is destroyed after the session
- ▶ RSA Handshake
 - ▶ if attacker records transmission and later gets private key from server he can decrypt the transmission
- ▶ DH-Key exchange
 - ▶ key exchange is ephemeral (volatile) because it only applies to the session and client and server generate a new key pair each time
 - ▶ key never goes over the network
- ▶ DH is perfect forward secret
- ▶ RSA handshake is removed from TLS 1.3



Handshake Problem

- ▶ Client and server negotiate cipher suite
- ▶ There are many cipher suites in TLS 1.2 (even weak ones)
- ▶ The protocol is signed only by the server and is vulnerable to tampering
- ▶ TLS 1.3 simplifies naming scheme, removes weak cipher suites, and signs the complete handshake protocol

Downgrade Attack (FREAK)

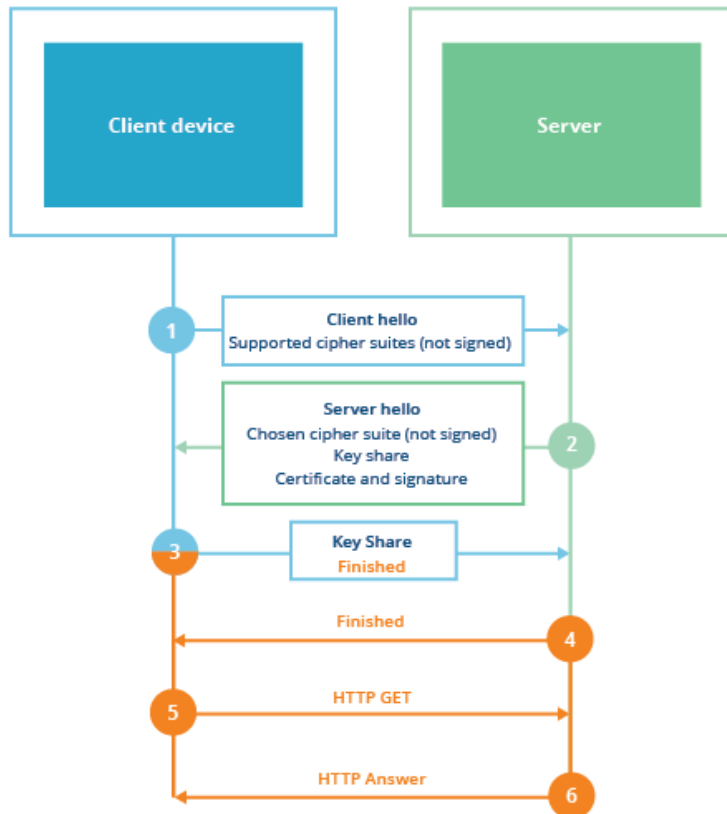


<https://blog.cloudflare.com/rfc-8446-aka-tls-1-3/>

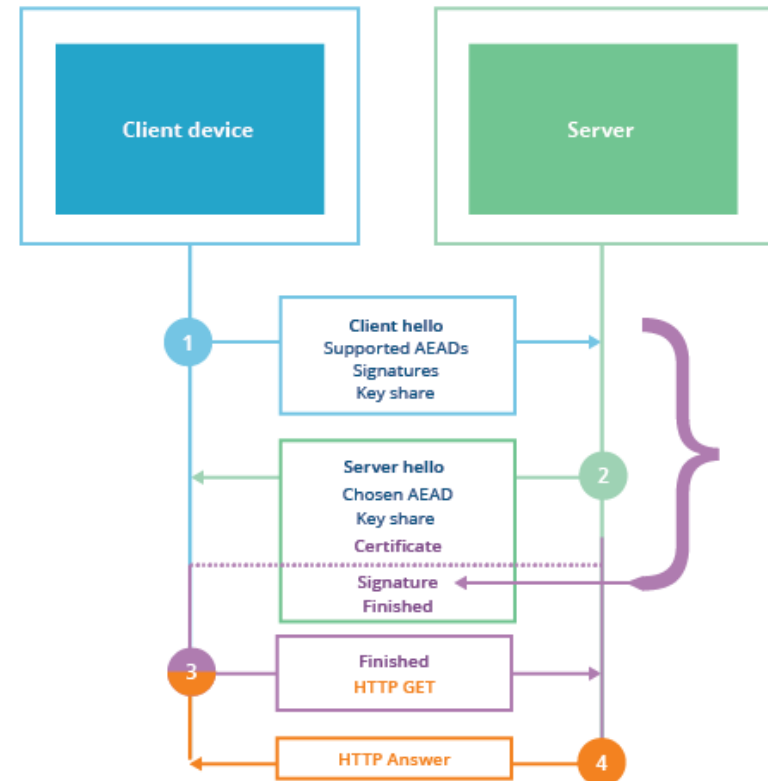


Signature of the entire handshake protocol in TLS 1.3

TLS 1.2 ECDHE



TLS 1.3

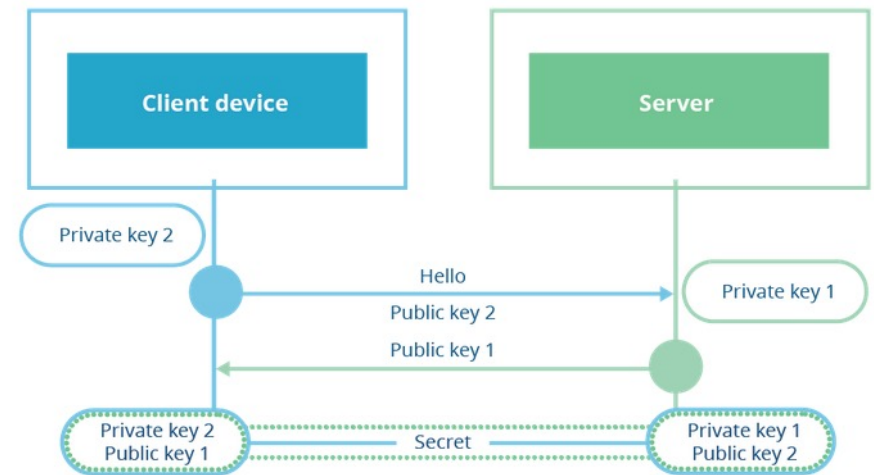


<https://blog.cloudflare.com/rfc-8446-aka-tls-1-3/>

▶ TLS 1.3 Handshake with 1-RTT-mode

- ▶ TLS 1.3 has much fewer key-agreement options
- ▶ The cipher has also been reduced to AEAD due to attacks on CBC, among other things
- ▶ This allows the client to send key shares in the first message
- ▶ Only one round trip between client and server
- ▶ 1-RTT (Round Trip Time)

DH 1.3 handshake



<https://blog.cloudflare.com/rfc-8446-aka-tls-1-3/>



SSL/TLS: Security and Limits

▶ SSL/TLS Security Properties

- ▶ Authenticated, confidential, and integer communication between two endpoints
- ▶ Security depends on the methods actually used
- ▶ Important: Encryption strength (key length ≥ 256 bits)
- ▶ HSTS Http Strict Transport Security
Flag in the header that tells browser to establish only encrypted connections to the domain
- ▶ With HTTPS Everywhere (Browser Plug-in) you can enforce TLS
<https://www.eff.org/de/https-everywhere>



▶ Limits of SSL/TLS

- ▶ Traffic flow analysis possible (who communicates with whom)
- ▶ No liability of the transmitted payload (as long as no client certificates)
 - ▶ Mutual TLS authentication required
- ▶ Firewalls can no longer analyze traffic
- ▶ Are certificates checked? Are warnings ignored?
- ▶ Is the master key and the session key securely stored?



Chapter 7.2: WLAN /WiFi

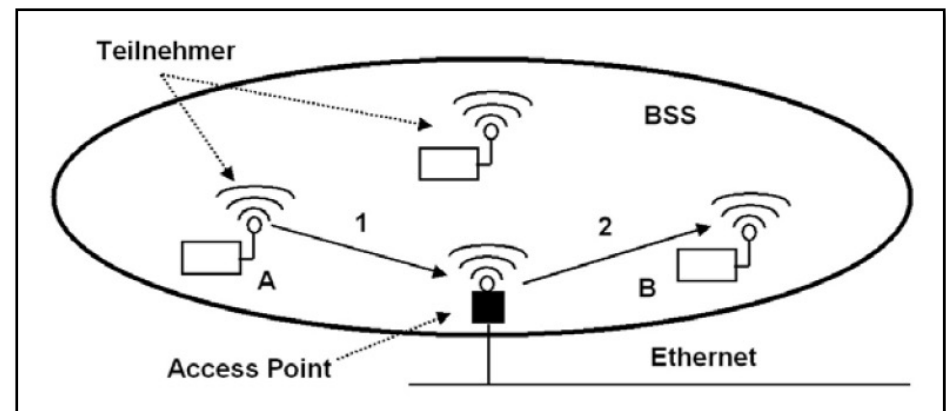
- WEP, WPA2
- WPA3

Security aspects of WLAN

- ▶ Attack Scenarios
 - ▶ War Driving
 - ▶ Rogue Access Point, Evil Twin
- ▶ Security considerations
 - ▶ Network availability (radio networks are more unstable)
 - ▶ Data integrity
 - ▶ Confidentiality



<http://de.wikipedia.org/w/index.php?title=Datei:WiFi-Motel.jpg&filetimestamp=20100524123410>
<http://creativecommons.org/licenses/by-sa/3.0/de/legalcode>



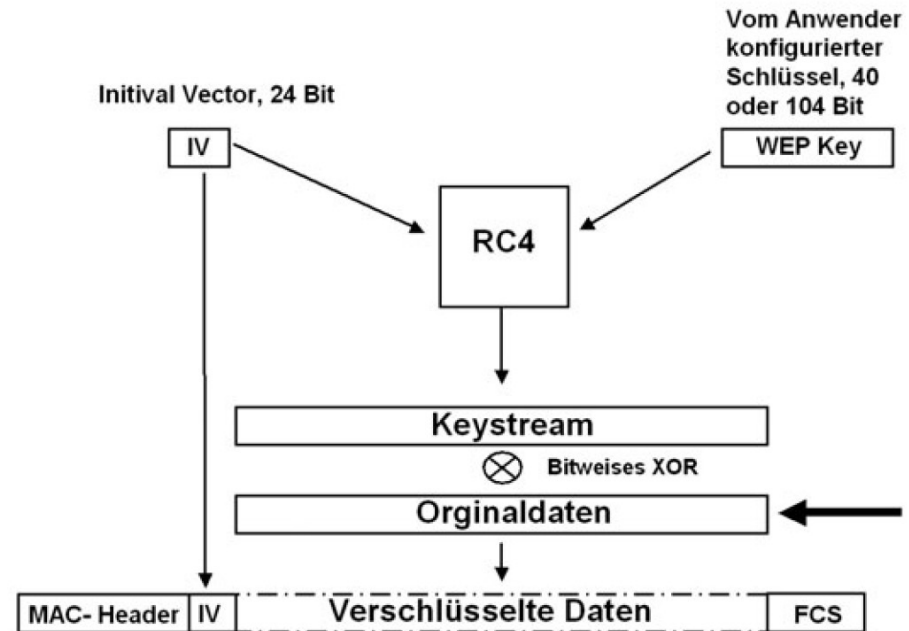
Infrastructure BSS Mode



WEP Wired Equivalent Privacy

Quelle: Grundkurs mobile Kommunikation,
M. Sauter, Vieweg + Teubner, 2011,
ebook in Bibliothek

- ▶ Encryption
 - ▶ One shared "secret" key
 - ▶ Encryption with RC4 and initialization vector
 - ▶ simple checksum
 - ▶ Cipher sequence is calculated for each packet
 - ▶ IV changes for each frame
- ▶ Problems:
 - ▶ Encryption (Short keys, IV too short)
 - ▶ Key management (only one key per network)
 - ▶ Authentication
 - ▶ same key for authentication and encryption
 - ▶ access point does not need to prove identity

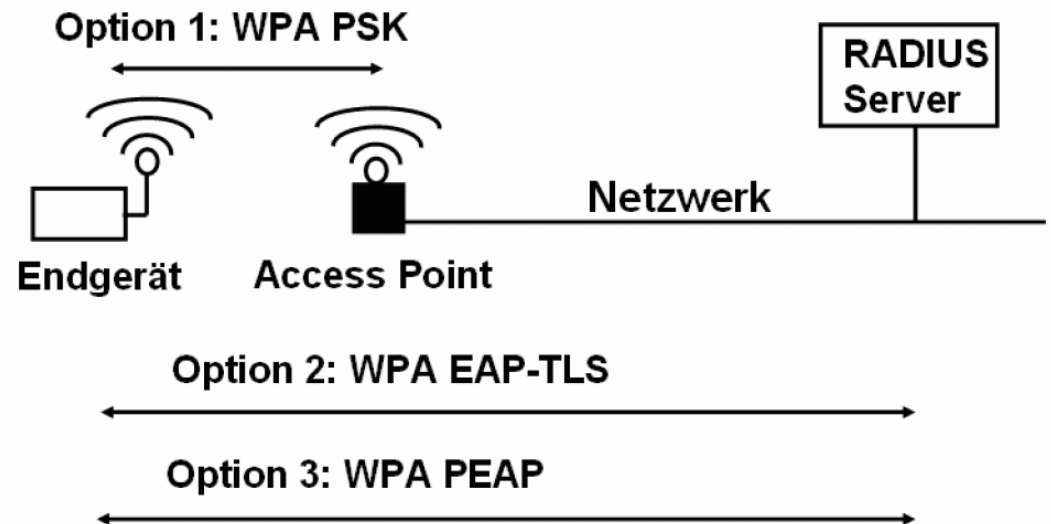




WPA2 Wi-Fi Protected Access

- ▶ Improving safety by
 - ▶ stronger encryption method (AES instead of RC4)
 - ▶ improved authentication
 - ▶ dynamic key generation
 - ▶ longer IV (48 bit)
 - ▶ cryptographic checksum MIC (Message Integrity Check)

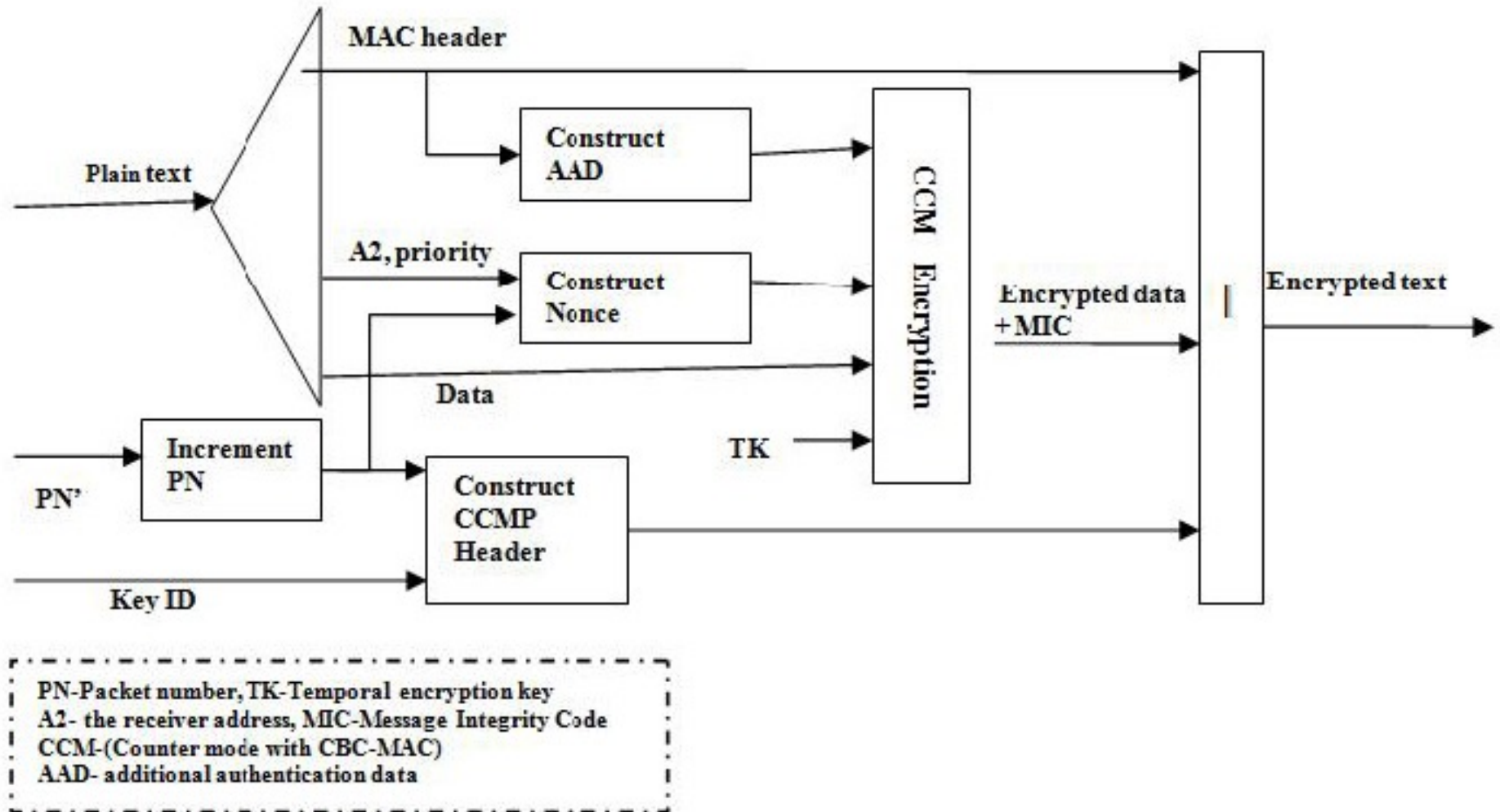
Three authentication methods:



Quelle: Grundkurs mobile Kommunikation, M. Sauter, Vieweg + Teubner, 2011 ebook in Bibliothek



WPA2 Encryption: CCMP Counter Mode with Cipher Block Chaining Message Authentication Code Protocol





Advantages of WPA2 over WEP

- ▶ IV longer (48 bit)
- ▶ IV is increased by one for each package
- ▶ Packets with already used IV are ignored (-> no replay attack)
- ▶ Individual session keys
- ▶ Master key is constantly renegotiated (at least once per hour) between the end device and the AP
- ▶ CRC and MIC can be used to distinguish transmission errors (MIC and CRC incorrect) from message manipulation (only MIC incorrect)



An attack on WPA2 shows weaknesses of WPA2

- ▶ KRACK attack on WPA2 (2017)
 - ▶ WPA2 encrypts with XOR
 - ▶ If you encrypt different data via XOR with the same key, you can calculate the plain text if you know the plain text of one data packet
 - ▶ WPA2 uses NONCE (one-time random number) as protection to calculate the key
 - ▶ The attacker intercepts the acknowledgement of receipt and the packet from the client
 - ▶ The router resends the packet
 - ▶ Client makes key reinstallation with old nonce
 - ▶ The client encrypts with old nonce
- ▶ Consequence: http injection or replay attacks are possible
- ▶ Prerequisite for attack
 - ▶ attack is only possible in the immediate vicinity of the devices (manipulate radio connection)
 - ▶ device is not patched (e.g. IoT devices)



The KRACK attack in detail

By **intercepting and blocking Msg4**, the attackers achieve that the AP resends Msg3 and thus triggers a re-installation of the keys and resets Nonce and replay counter r .

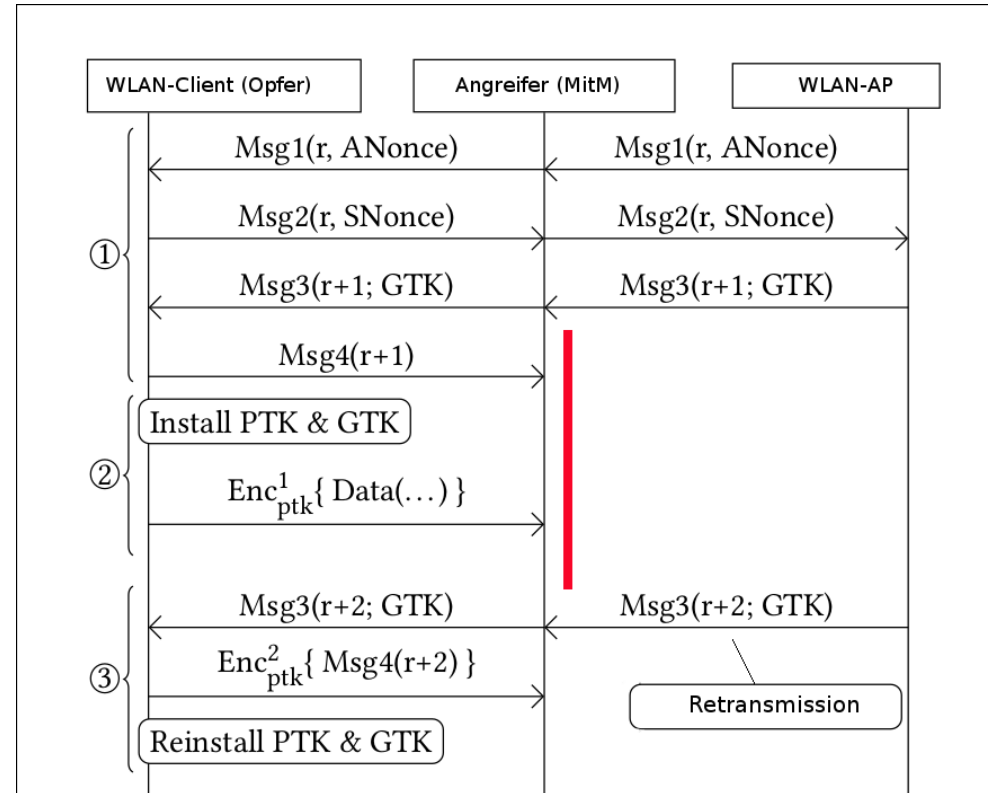
(Figure: Mathy Vanhoef and Frank Piessens)

Video of the demonstration of an attack

<https://youtu.be/Oh4WURZoR98>



Attack on 4-way handshake



<https://www.heise.de/security/artikel/KRACK-so-funktioniert-der-Angriff-auf-WPA2-3865019.html>

<https://www.krackattacks.com/>



Improvements in WPA3

- ▶ **"Simultaneously Authentication of Equals handshake" (SAE)**
 - ▶ the WPA2 key exchange with 4-way handshake (Pre-Shared Key Exchange) has vulnerabilities
 - ▶ e.g. offline dictionary attacks are possible to crack a password
 - ▶ WPA3 relies on SAE (<https://ieeexplore.ieee.org/document/4622764>) based on Dragonfly Protocol (IRTF RFC 7664 & IEEE 802.11 hrs.)
 - ▶ WPA3 thus fulfills forward secrecy and is resistant to offline decryption
- ▶ **OWE Opportunistic Wireless Encryption**
 - ▶ rules encryption in open Wi-Fi networks
 - ▶ does not require a password and is based on DH
 - ▶ replaces insecure 802.11. Open System Authentication
 - ▶ it is not an authentication, therefore there is no protection against honeypot APs and Evil Twins



Improvements in WPA3

- ▶ **Device Provisioning Protocol (DPP)**
 - ▶ Replaces WPA2's WPS (Wi-Fi Protected Setup) which is vulnerable to attacks
 - ▶ Simplified process for configuring devices
 - ▶ DPP enables (IoT) devices to authenticate to WLAN with QR Code or NFC (Near Field Communication)
 - ▶ Wi-Fi Certified Easy Connect Standard
- ▶ Better Encryption GCM-256 (WPA2 CCM-128)
- ▶ Videos with details about DLC, OWE, SAE, DPP
 - <https://www.youtube.com/watch?v=T5RTp0HSHoo> DLC
 - <https://www.youtube.com/watch?v=E2r5QkgQpUM> OWE
 - <https://www.youtube.com/watch?v=HXDZwlkejhA> SAE
 - <https://www.youtube.com/watch?v=ssoMsZlunQw> DPP
- ▶ WPA3 is in use since 2019



Summary Secure Communication



- ▶ Two well-known encrypted protocols are WLAN and SLL/TLS
- ▶ For both communication protocols, various cryptographic methods are used (MAC, DH, AES, RSA, ...)
- ▶ Both protocols had vulnerabilities and must be constantly further developed
- ▶ For secure communication, the networks must also be secured (firewall, IDS, DMZ, ...)
- ▶ For secure communication, the applications must also be secured (e.g encrypted e-mail)